

Rapport de Lab — Sécurité Mobile Android

LAB 03 : Observation du trafic HTTP(S) Android avec Burp Suite

Chagdaly Hiba

15 mai 2026

Table des matières

1	Informations générales	3
2	Objectifs	3
3	Environnement de laboratoire	3
3.1	Architecture réseau	3
3.2	Outils utilisés	3
4	Déroulement du lab	3
4.1	Étape 1 — Préparation de Burp Suite	3
4.2	Étape 2 — Configuration du Proxy Listener	4
4.3	Étape 3 — Identification de l'adresse IP hôte	5
4.4	Étape 4 — Configuration du proxy côté Android	5
4.5	Étape 5 — Test de capture HTTP	6
4.6	Étape 6 — Analyse d'une requête interceptée	7
4.7	Étape 7 — Interception contrôlée	8
5	Observations et analyse	10
5.1	Données observées en transit	10
5.2	HTTP vs HTTPS	10
6	Risques potentiels identifiés	10
7	Recommandations	10
8	Conclusion	11

1 Informations générales

Champ	Valeur
Date d'analyse	15 mai 2026
Analyste	Chagdaly Hiba
Outil principal	Burp Suite Community
Émulateur Android	Genymotion Phone_2 (Android 10 - API 29)
IP machine hôte	192.168.249.2
Port proxy	8080
Cible	http ://example.com (site de test autorisé)

TABLE 1 – Informations générales du lab

2 Objectifs

Ce lab a pour objectif de mettre en place un proxy d'observation entre un émulateur Android et une application cible autorisée. Les objectifs spécifiques sont :

- Comprendre comment un proxy s'insère dans le chemin réseau
- Capturer et analyser des requêtes HTTP depuis un émulateur Android
- Identifier les éléments essentiels d'une requête HTTP
- Comprendre la différence entre HTTP et HTTPS
- Produire une trace d'audit documentée

3 Environnement de laboratoire

3.1 Architecture réseau

L'architecture mise en place pour ce lab est la suivante :

Genymotion (192.168.249.101) → Burp Suite (192.168.249.2:8080) → Internet

3.2 Outils utilisés

Outil	Version	Rôle
Burp Suite Community	2024.x	Proxy d'interception
Genymotion Desktop	3.10.0 PRO	Émulateur Android
Android	10 (API 29)	Système cible
VMware Workstation Pro	17	Hyperviseur

TABLE 2 – Outils utilisés

4 Déroulement du lab

4.1 Étape 1 — Préparation de Burp Suite

Burp Suite a été lancé en mode projet temporaire. L'onglet Proxy a été configuré avec l'interception désactivée (*Intercept is off*) pour permettre l'observation passive du trafic

sans bloquer les requêtes.

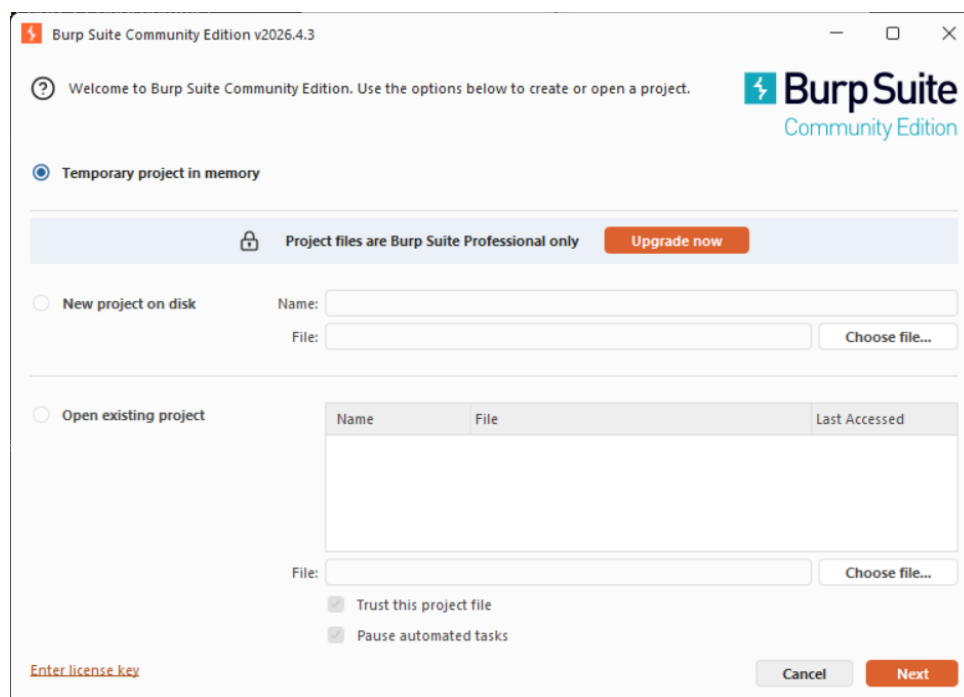


FIGURE 1 – Burp Suite — Proxy prêt avec interception désactivée

4.2 Étape 2 — Configuration du Proxy Listener

Le listener Burp a été configuré pour écouter sur toutes les interfaces réseau (*All interfaces*) sur le port 8080. Cette configuration est nécessaire pour que l'émulateur Android puisse atteindre Burp depuis son réseau VirtualBox.

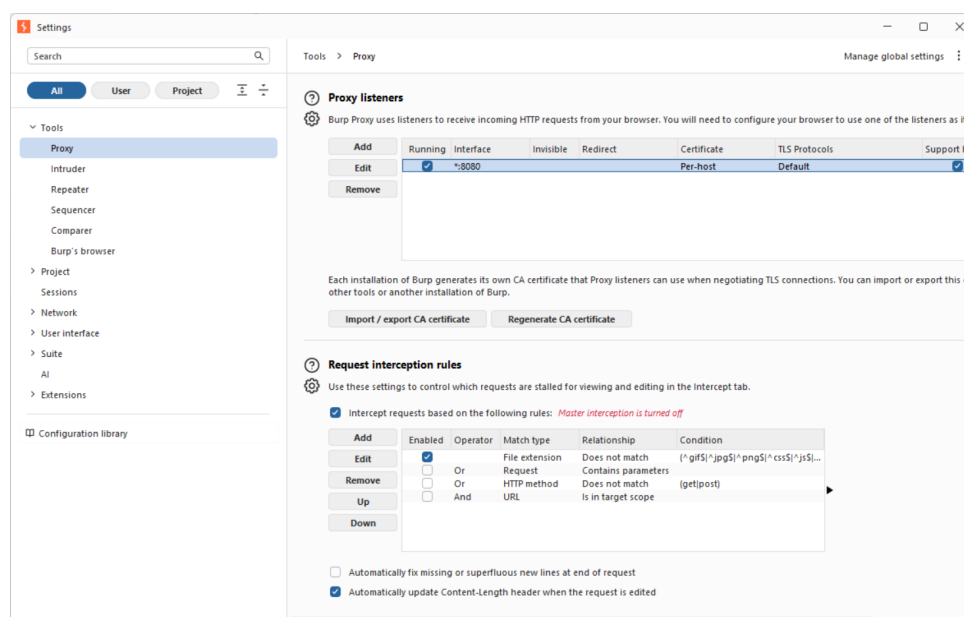


FIGURE 2 – Burp Suite — Listener actif sur le port 8080

4.3 Étape 3 — Identification de l'adresse IP hôte

La commande `ipconfig` a été exécutée sur la machine hôte Windows pour identifier l'adresse IP accessible depuis l'émulateur. L'interface **Ethernet 2** avec l'adresse `192.168.249.2` a été retenue car elle est sur le même sous-réseau que Genymotion (`192.168.249.x`).

```
Ethernet adapter Ethernet 2:

Connection-specific DNS Suffix . : 
Link-local IPv6 Address . . . . . : fe80::8e7a:c22a:f8ad:48b7%100
IPv4 Address. . . . . : 192.168.249.2
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . :
```

FIGURE 3 – `ipconfig` — Identification de l'IP hôte `192.168.249.2`

4.4 Étape 4 — Configuration du proxy côté Android

Dans l'émulateur Genymotion, les paramètres WiFi ont été modifiés pour configurer un proxy manuel pointant vers `192.168.249.2:8080`.

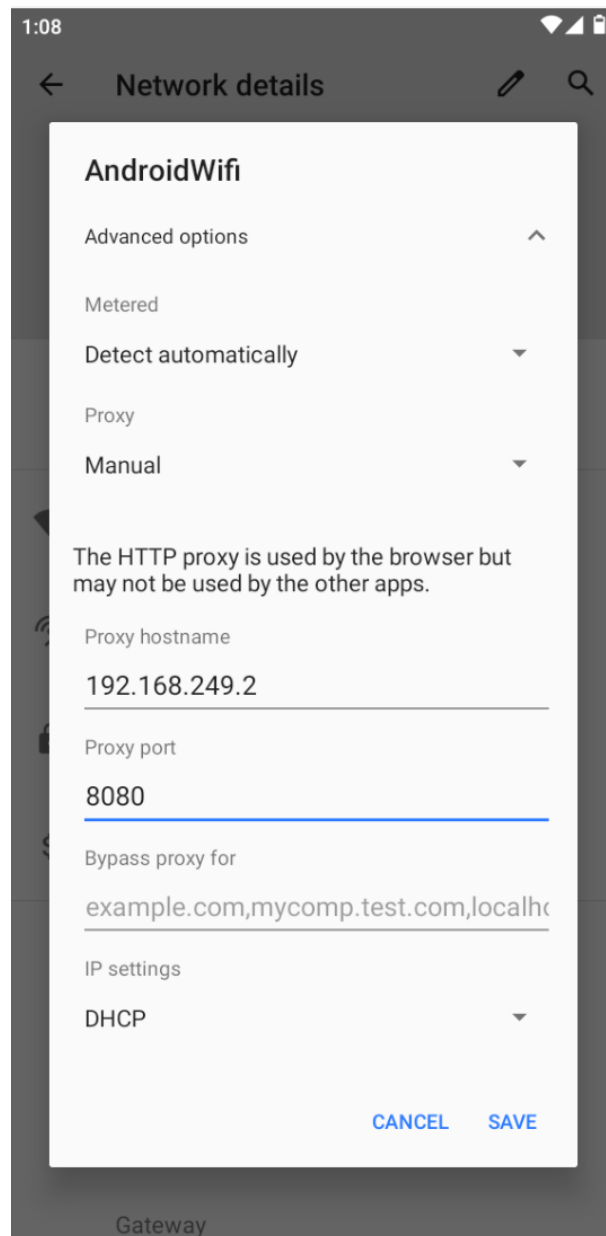


FIGURE 4 – Genymotion — Configuration du proxy manuel

4.5 Étape 5 — Test de capture HTTP

Le navigateur de l'émulateur a été utilisé pour accéder à `http://example.com`. La page s'est chargée correctement, confirmant que le routage via le proxy fonctionne.

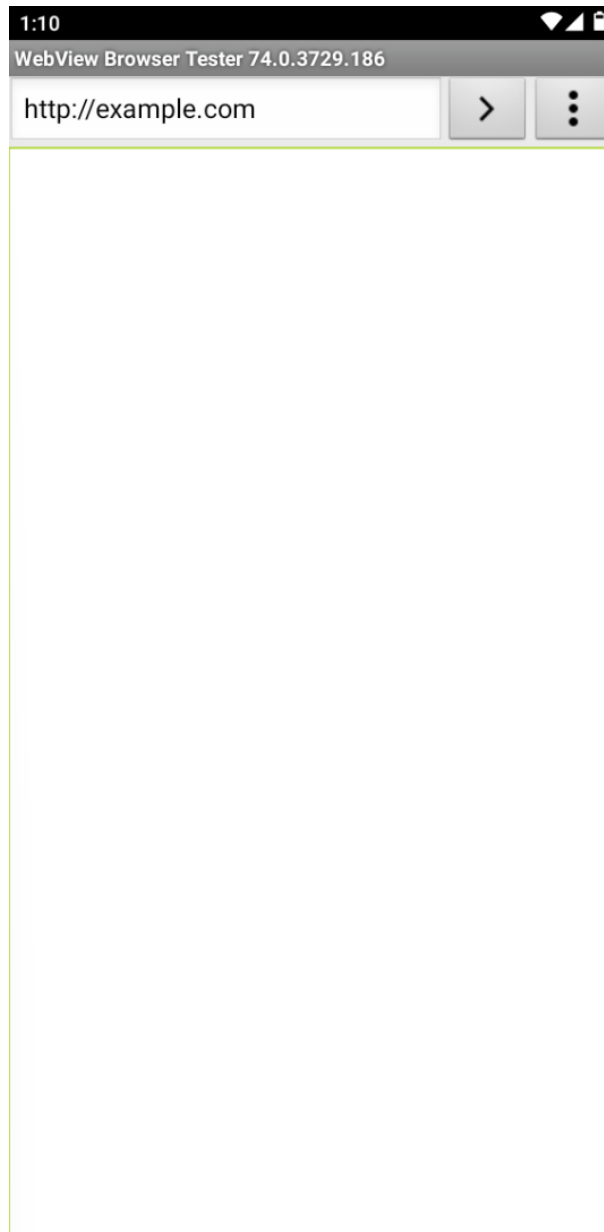


FIGURE 5 – Genymotion — Chargement de example.com via le proxy

4.6 Étape 6 — Analyse d’une requête interceptée

Dans Burp Suite, l’onglet HTTP history a affiché les requêtes capturées. L’analyse d’une requête GET vers `example.com` a révélé les éléments suivants :

- **Méthode** : GET
- **URL** : `http://example.com/`
- **Headers** : Host, User-Agent, Accept, Accept-Encoding
- **Cookies** : Aucun (site de test)
- **Paramètres** : Aucun

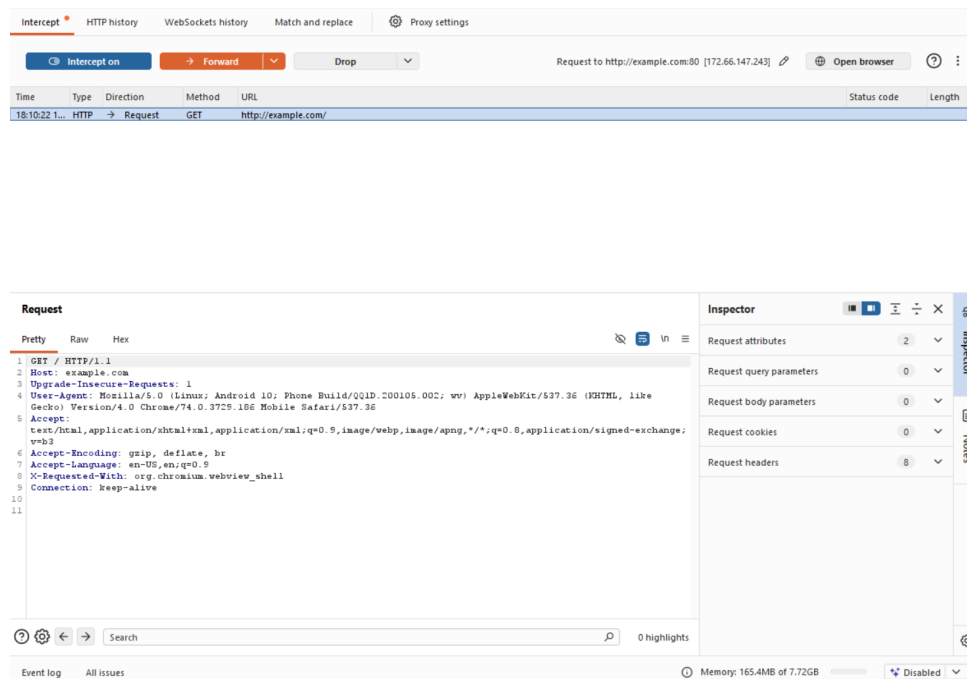


FIGURE 6 – Burp Suite — Détail d’une requête HTTP interceptée

4.7 Étape 7 — Interception contrôlée

L’interception a été activée brièvement pour démontrer le principe du proxy actif. La requête a été mise en attente dans Burp avant d’être transmise. L’interception a ensuite été désactivée.

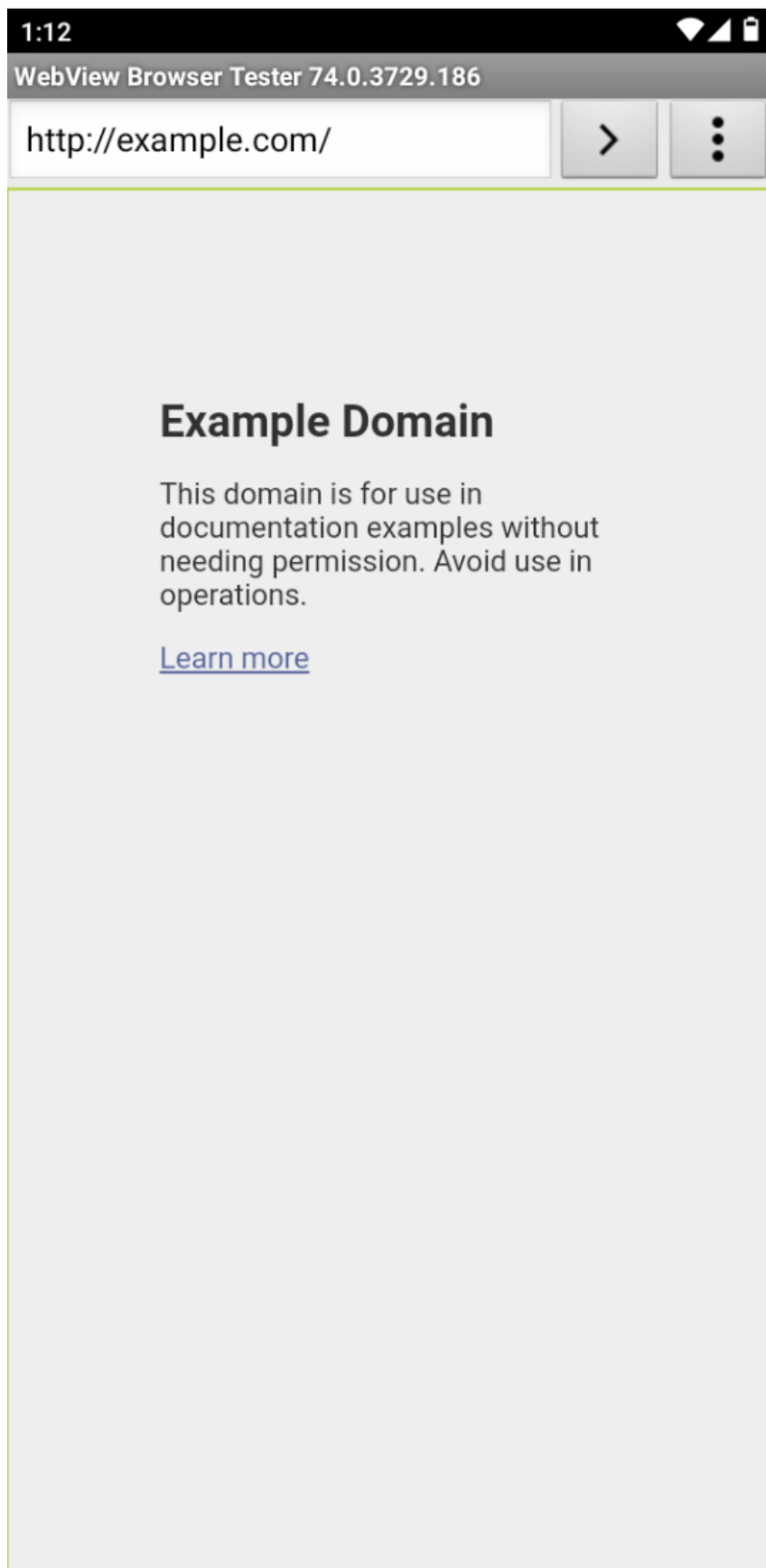


FIGURE 7 – Genymotion — Page chargée après transmission de la requête

5 Observations et analyse

5.1 Données observées en transit

L'analyse du trafic HTTP capturé a permis d'identifier les éléments suivants transitant en clair :

Élément	Valeur observée	Risque
URL complète	http ://example.com/	Faible
User-Agent	Android WebView	Faible
Headers HTTP	Host, Accept, etc.	Faible
Cookies	Aucun	N/A
Données POST	Aucune	N/A

TABLE 3 – Éléments observés en transit

5.2 HTTP vs HTTPS

Le trafic HTTP transite en clair et est entièrement lisible par Burp. Le trafic HTTPS, en revanche, est chiffré et nécessite l'installation d'un certificat CA proxy sur l'émulateur pour être déchiffré. Sans ce certificat, le navigateur affiche une erreur SSL.

6 Risques potentiels identifiés

#	Risque	Sévérité
1	Utilisation de HTTP non chiffré	Élevée
2	Absence d'en-têtes de sécurité	Moyenne
3	User-Agent révèle l'environnement	Faible

TABLE 4 – Risques potentiels identifiés

7 Recommandations

1. **Utiliser HTTPS** pour toutes les communications réseau de l'application mobile.
2. **Implémenter le SSL Pinning** pour empêcher l'interception même avec un certificat CA compromis.
3. **Minimiser les données** transmises dans les headers HTTP (User-Agent, etc.).
4. **Sécuriser les cookies** avec les attributs `Secure` et `HttpOnly`.
5. **Ajouter des en-têtes de sécurité** côté serveur (HSTS, X-Content-Type-Options, etc.).

8 Conclusion

Ce lab a permis de mettre en place avec succès un environnement d'interception de trafic HTTP entre un émulateur Android et Internet. L'utilisation de Burp Suite comme proxy a démontré la facilité avec laquelle le trafic non chiffré peut être observé et analysé.

Les concepts fondamentaux du proxy réseau, de la configuration côté client Android, et de l'analyse de requêtes HTTP ont été maîtrisés. La prochaine étape (Lab 15) consistera à aller plus loin en contournant le SSL Pinning pour analyser également le trafic HTTPS.